REPORTE: ANÁLISIS DE VULNERABILIDADES CON OWASP ZAP EN GIN & JUICE SHOP

MARIA ROSARIO MAMANI POMA

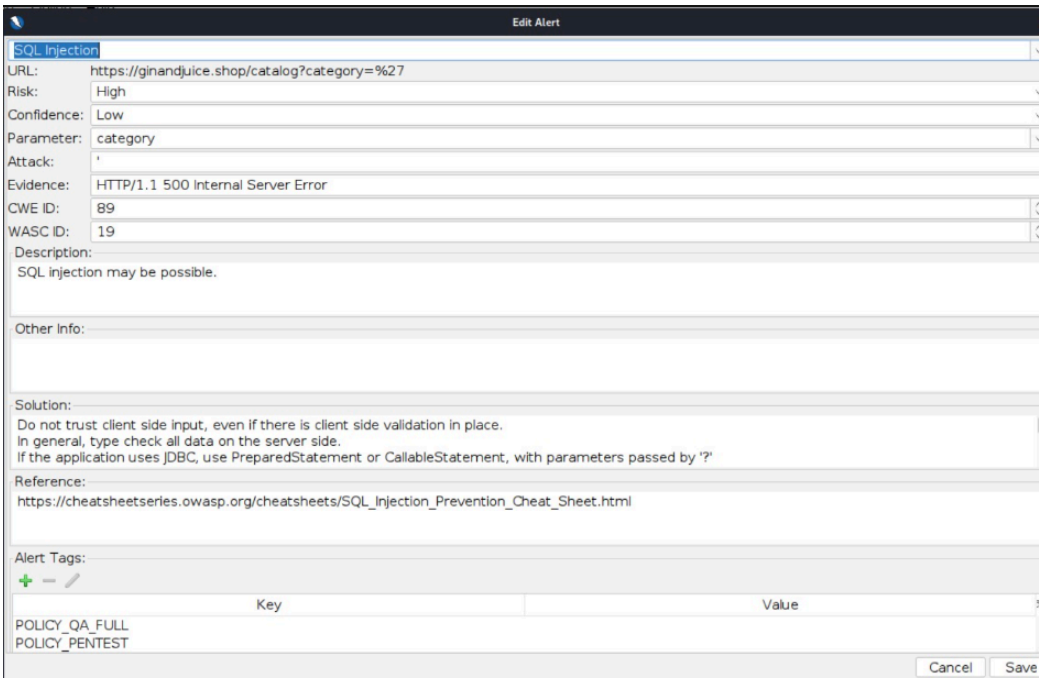
26-10-2026

Sitio de prueba: https://ginandjuice.shop/

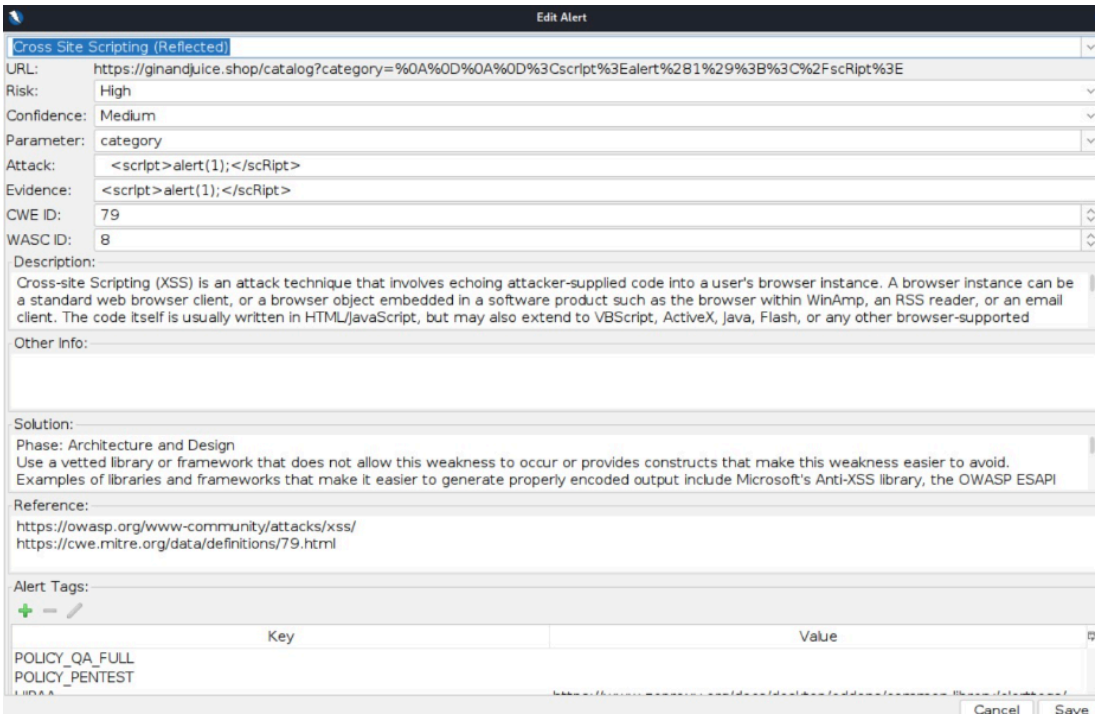
↘ Análisis de alertas (documentar 3 alertas de tipos distintos)

ZAP reportó 12 alertas en total. Documentar una de cada tipo:

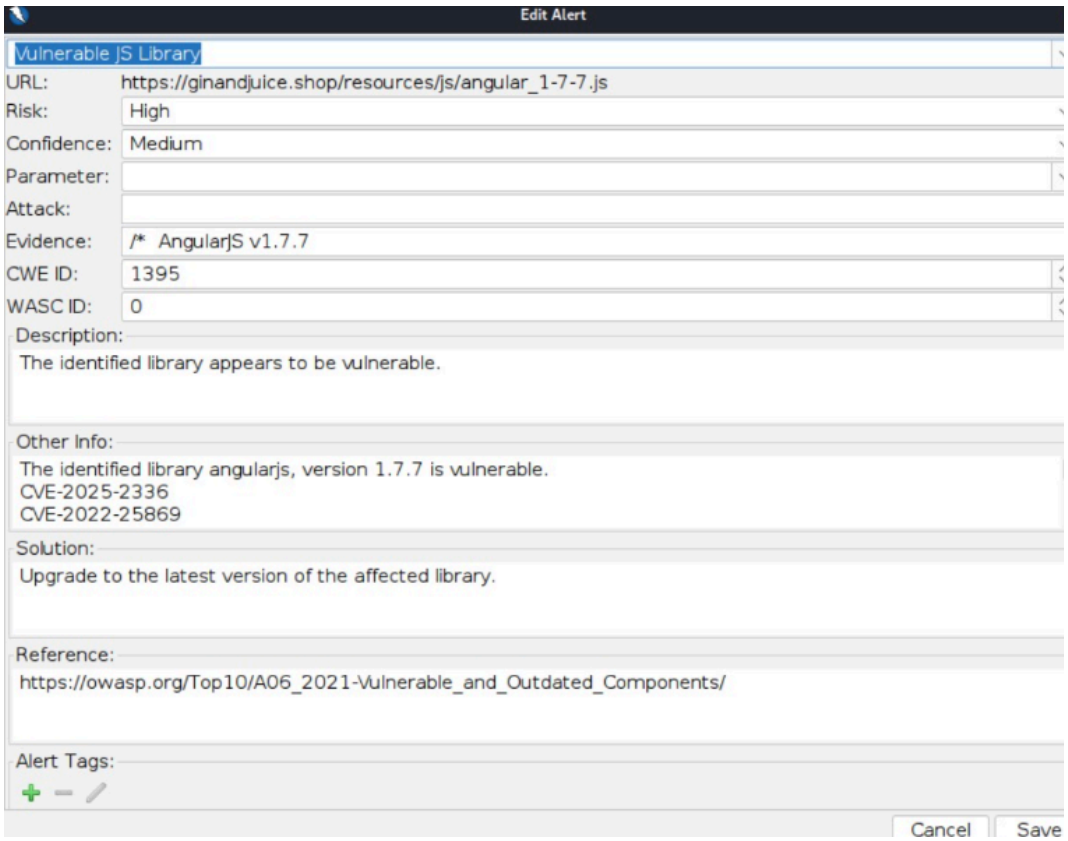
1. Dos (2) SQL Injection, nivel Alto.



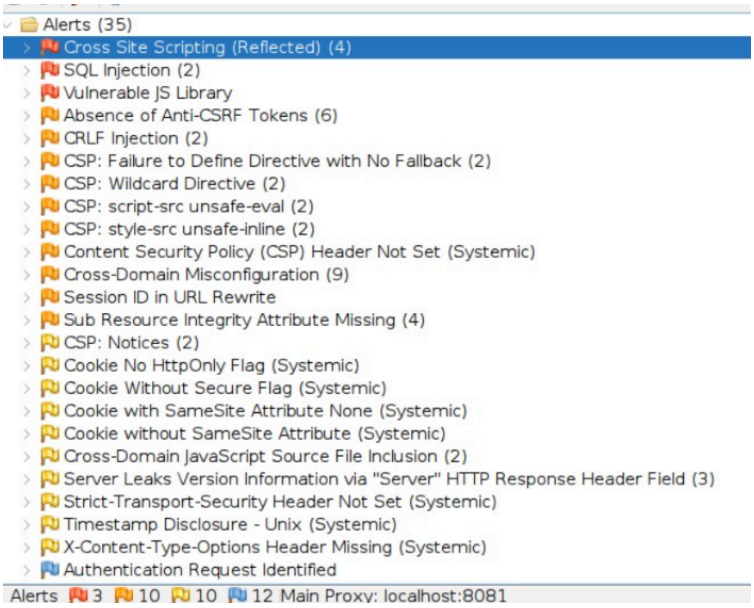
2. Cinco (5) Cross-Site Scripting (XSS), nivel Medio.

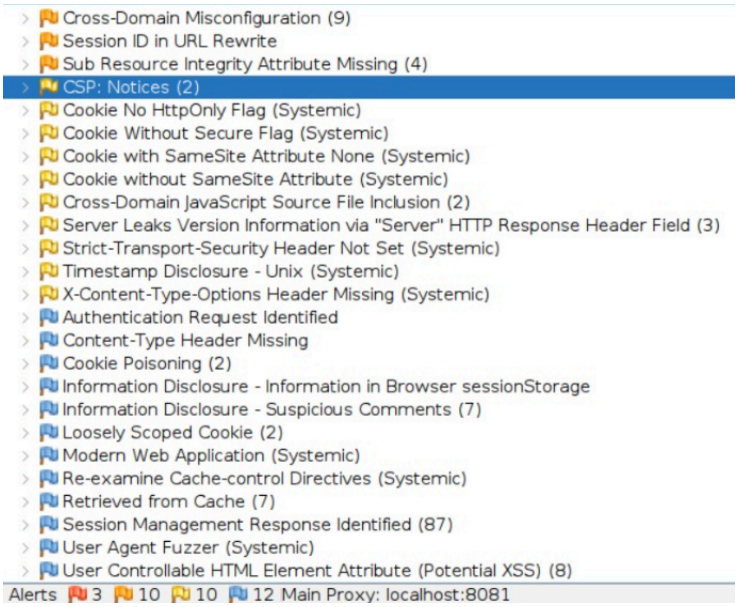


3. Un (1) Vulnerable JS library, nivel Alto



Alertas encontradas:





Hallazgo principal (ficha técnica de 8 elementos)

1	**Nombre de la alerta**	SQL Injection
2	**Nivel de riesgo**	High
3	**URL o componente**	https://ginand»ice.shop/catalog ?categorF%27
4	**Parámetro afectado**	category
5	**Evidencia**	HTTP/I.1 500 Internal server Error
6	**Descripción técnica**	El parámetro devuelve una respuesta de error 500
7	**Impacto potencial**	Acceso no autorizado a la información de la base de datos
8	**Recomendación**	Usar una biblioteca o framework validado que no permita que esta debilidad ocurra, o que proporcione constructos que faciliten evitarla. Ejemplos de bibliotecas y frameworks que facilitan la generación de salida correctamente codificada incluyen la biblioteca Anti-XSS de Microsoft y OWASP ESAPI.

Conclusiones

¿Qué aprendí?

ZAP me proporcionó información sobre las vulnerabilidades encontradas en la aplicación y me ayudó a identificarlas mediante su módulo de análisis automatizado. Además, cuenta con un módulo de proxy que permite capturar el tráfico y editar las consultas HTTP.

¿Qué fue lo más retador?

Replicar los errores, identificar cuales son los parámetros afectados, se resolvió realizando un reconocimiento

¿Qué revisaría a continuación?

Revisaría qué otros parámetros de la aplicación podrían presentar la misma vulnerabilidad. Después, aplicaría las recomendaciones de corrección y repetiría las pruebas hasta confirmar que el error fue solucionado.

Tabla final de resumen

Risk Level	Name	URL	Parameter	Evidence
High	**SQL Injection**	https://ginand»ice.shop/catalog ?categorF%27	category	HTTP/I.1 500 Internal server Error
High	**Cross site Scripting (Reflected)**	https://ginandjuice.shop/catalog?category=%OA%OD%OA%OD%3Cscrlpt%3Ealert%281%29%3B%3C%2FscRipt%3E	category	<script>alert(1); </scRipt>
High	**Vulnerable JS**	https://ginandjuice.shop/resources/js/angular_1-7-7.js		/* AngularJS v1.7.7